

Air University



SSDD (Lab)

Year 2026

Mr. Anjum Rehman

Academic Year: 2024 – 2028

Department of Cyber Security

USAMA ARSHAD | 247141

BS – Cyber Security – Fall – 24 (A)

Date of Submission: March 10, 2026

Lab Task # 06

Question # 01 (Attack Tree)

Scenario: Securing an E-Commerce Website

In this scenario, we will explore the security of an e-commerce website, a critical online platform for a retail business. E-commerce websites handle sensitive customer information, financial transactions, and a wide range of products, making them attractive targets for cyber threats. Let's outline a hypothetical scenario in which an attack tree can be constructed to assess and improve the website's security.

Scenario Description:

"TechTrends" is a growing e-commerce company that specializes in selling the latest consumer electronics online. Their website is the primary way customers browse products, place orders, and manage their accounts. With the increasing importance of online shopping, TechTrends recognizes the need to enhance the security of its e-commerce platform.

Attack Tree Scenario:

Category 1: Web Application Security

- **Sub-Tree 1: SQL Injection**
 - Attack Vector 1: Exploiting SQL injection vulnerabilities in user input fields.
 - Attack Vector 2: Tampering with database queries to extract sensitive data.
- **Sub-Tree 2: Cross-Site Scripting (XSS)**
 - Attack Vector 1: Injecting malicious scripts into the website's content.
 - Attack Vector 2: Stealing user session cookies to impersonate customers.
- **Sub-Tree 3: Security Misconfigurations**
 - Attack Vector 1: Improperly configured server settings and permissions.
 - Attack Vector 2: Exposed server directories or files containing sensitive data.

Category 2: Payment Processing

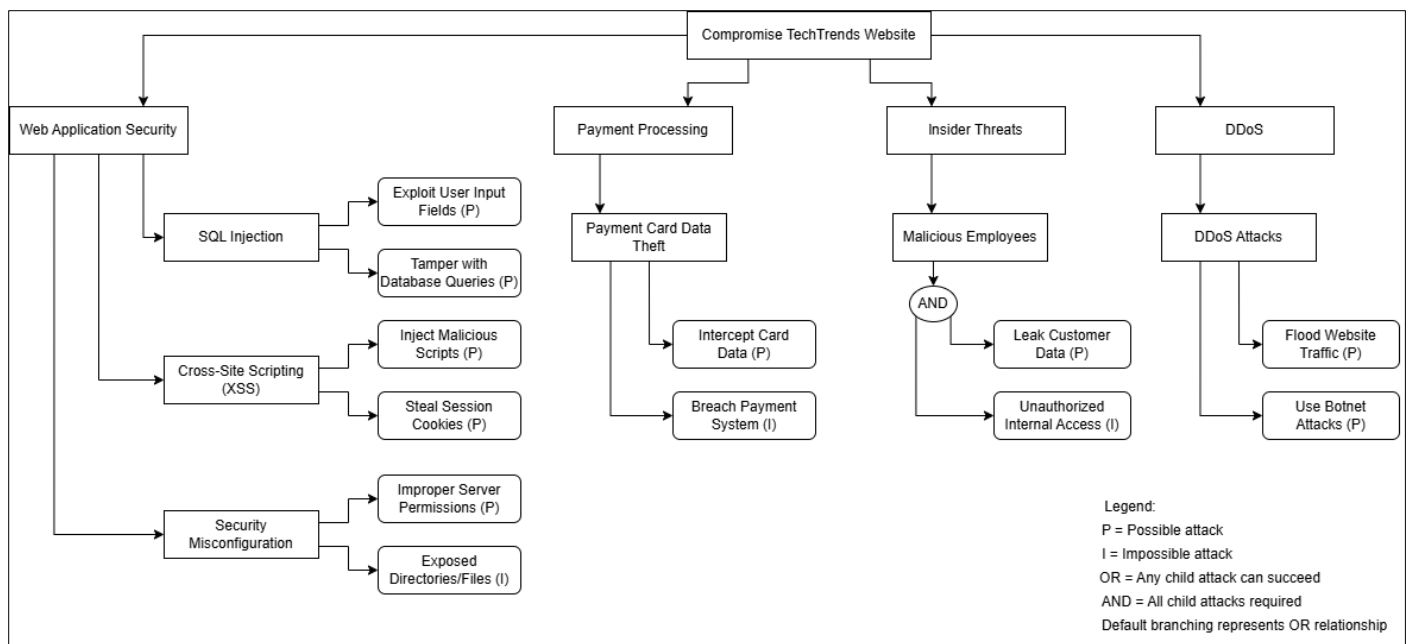
- **Sub-Tree 4: Payment Card Data Theft**
 - Attack Vector 1: Intercepting credit card data during transactions.
 - Attack Vector 2: Breaching the payment processing system.

Category 3: Insider Threats

- **Sub-Tree 5: Malicious Employees**
 - Attack Vector 1: Employees intentionally leaking customer data.
 - Attack Vector 2: Unauthorized access by disgruntled employees with access to the system.

Category 4: Distributed Denial of Service (DDoS)

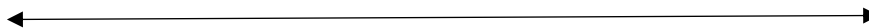
- **Sub-Tree 6: DDoS Attacks**
 - Attack Vector 1: Flooding the website with traffic to disrupt operations.
 - Attack Vector 2: Utilizing botnets to launch coordinated DDoS attacks.

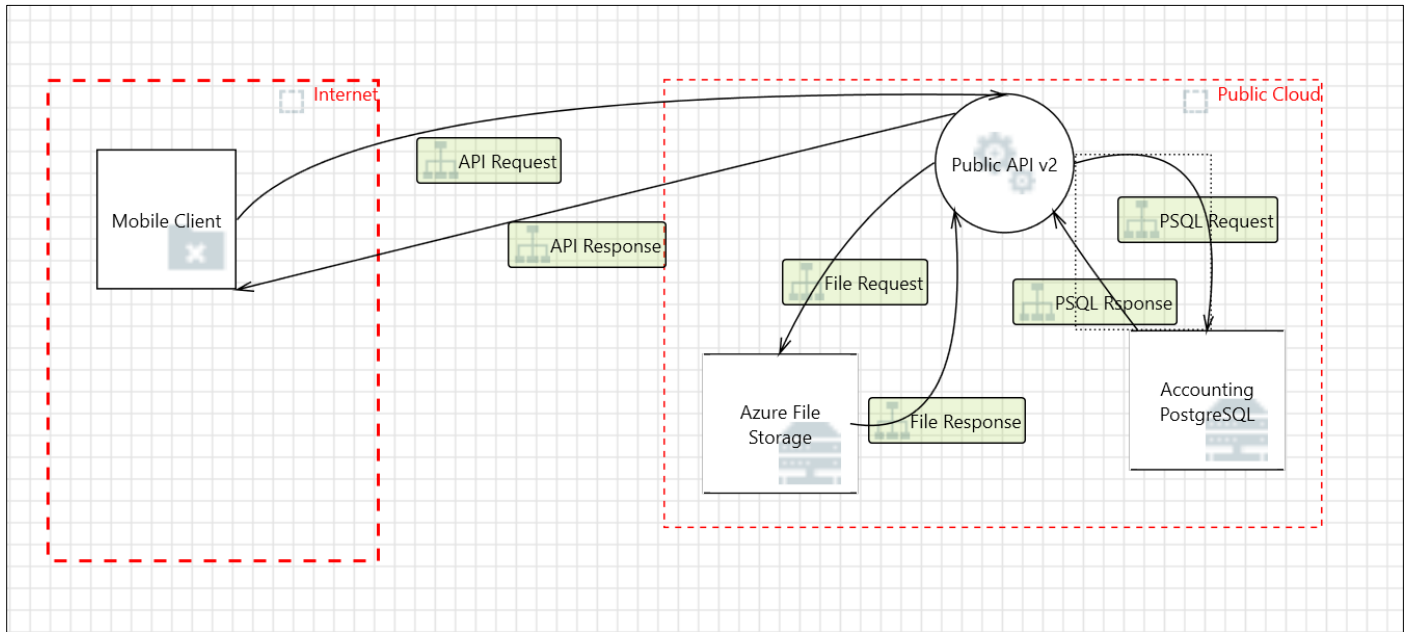
Solution:**Attack Tree Analysis — TechTrends E-Commerce Platform**

This analysis shows potential threats to the TechTrends e-commerce website. It focuses on compromising the platform and is broken down into four main categories.

- 1. Web Application Security** has the highest risk. Threats like SQL Injection and Cross-Site Scripting (XSS) are Possible (P) because tools for these attacks are easy to find. Security Misconfiguration is Partially Possible (PP), meaning servers often have incorrect settings. Exposed directories are Impossible (I) because modern web servers usually block directory listing.
- 2. Payment Processing** has limited threats. It is Possible (P) to intercept credit card data using man-in-the-middle attacks. However, it is Impossible (I) to directly breach payment systems due to strong encryption and compliance controls (PCI-DSS).
- 3. Insider Threats** need both data leakage and unauthorized access to happen together. Data leakage is Possible (P) since it requires someone with access to share the data. Unauthorized access is Impossible (I) if proper Role-Based Access Control (RBAC) is in place.
- 4. DDoS Attacks** are Possible (P) because DDoS-for-hire services and botnets can launch attacks on public websites.

This analysis highlights the need for strong security measures to address these risks.



Question # 02 (STRIDE)**DFD****Small Threat List:**

67	Diagram 1	Generated	Not Started	Spoofing of Destir	Spoofing	Accounting Postgre:	PSQL Request	High
68	Diagram 1	Generated	Not Started	Potential Excessive	Denial Of Service	Does Public API v2	PSQL Request	High
69	Diagram 1	Generated	Not Started	Spoofing of Sourc	Spoofing	Accounting Postgre:	PSQL Response	High
70	Diagram 1	Generated	Not Started	Weak Access Cont	Information Disclosure	Improper data prot	PSQL Response	High
71	Diagram 1	Generated	Not Started	Spoofing of Destir	Spoofing	Azure File Storage n	File Request	High
72	Diagram 1	Generated	Not Started	Potential Excessive	Denial Of Service	Does Public API v2	File Request	High
73	Diagram 1	Generated	Not Started	Spoofing of Sourc	Spoofing	Azure File Storage n	File Response	High
74	Diagram 1	Generated	Not Started	Weak Access Cont	Information Disclosure	Improper data prot	File Response	High

The Threat Modeling report has been attached via an HTML link, and a PDF has also been uploaded.

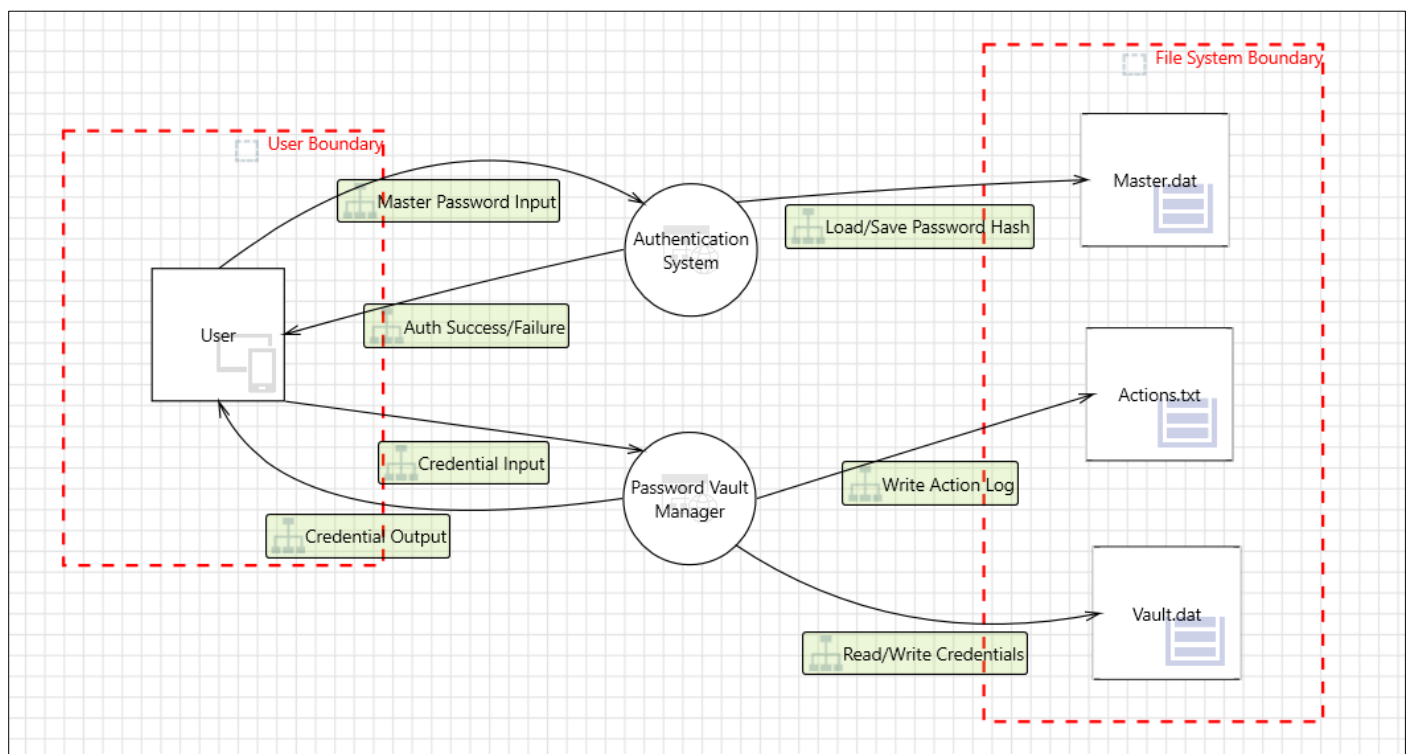
HTML Link:

<file:///D:/University/Secure%20Software%20Design%20&%20Development/Lab/Lab%206/Q2.Report.htm>

**Question # 03 (STRIDE)**

Generate a basic DFD of your Final Year Project and generate its report. If you aren't doing FYP, you can choose any of your previous semester projects to complete this task.

Chosen Project: Password Vault

DFD:**Small Threat List:**

ID	Diagram	Changed I	Last Modified	State	Title	STRIDE Category	Description	Just	Interaction	Possible Mitigation(s)	Severit	SDL Phase
0	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary may jail bre	Elevation of Privileges	An adversary	An adv	Master Password	Implement implicit jailbre	High	Design
1	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can reverse	Information Disclosure	An adversary	An adv	Master Password	Do not expose security de	High	Implementation
2	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary may gain a	Information Disclosure	An adversary	An adv	Master Password	Ensure that the applicatio	High	Implementation
3	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can gain ac	Information Disclosure	An adversary	An adv	Master Password	Implement Certificate Pin	High	Implementation
4	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can gain se	Information Disclosure	If application	If the a	Master Password	Encrypt sensitive or PII da	High	Implementation
5	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can gain ac	Information Disclosure	An adversary	An adv	Master Password	Do not expose security de	High	Implementation
6	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	Attacker can deny the m	Repudiation	Proper loggin	Withou	Master Password	Ensure that auditing and I	Medium	Implementation
7	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can spoof i	Spoofing	Ensure that TL	An adv	Master Password	Verify X.509 certificates us	High	Implementation
8	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can steal se	Spoofing	Attackers can	An atta	Master Password	Explicitly disable the auto	High	Implementation
9	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can create i	Spoofing	Phishing is att	Phishin	Master Password	Verify X.509 certificates us	High	Implementation
10	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary may spoof	Spoofing	If proper auth	If prop	Master Password	Consider using a standar	High	Design
11	Diagram 2	ELITEBOOK\H	10-Mar-26 5:1	Needs Investig	An adversary can reverse	Tampering	An adversary	An adv	Master Password	Obfuscate generated bin	High	Design

The Threat Modeling report has been attached via an HTML link, and a PDF has also been uploaded.

HTML Link:

<file:///D:/University/Secure%20Software%20Design%20&%20Development/Lab/Lab%206/Q3.Report.htm>

- END of Lab Task -